Controls and compliance checklist

Select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control	Explanation
☐	☑	Least Privilege	Currently all employees have access to customer data. Privileges need to be limited to reduce the risk of breach.
☐	☑	Disaster recovery plans	No disaster recovery plans in place presently. To ensure business continuity it should be implemented.
☐	☑	Password policies	Requirements for passwords are minimal which makes it easier for threat actors to easily get access to secure data by brute forcing through the network.
☐	☑	Separation of duties	None in place. Needs to be implemented to reduce the risk of fraud and access to critical data.
☑	☐	Firewall	The existing firewall blocks traffic based on an appropriately defined set of security rules.
☐	☑	Intrusion detection system (IDS)	No IDS installed. Need to be setup to detect possible intrusion attempts.
☐	☑	Backups	The IT department needs to have backups of critical data, in the case of a breach.

☑	☐	Antivirus software	Antivirus software is installed and monitored regularly by the IT department.
☐	☑	Manual monitoring, maintenance, and intervention for legacy systems	Risk assessment indicates - although legacy systems are monitored and maintained, there is no regular schedule in place for these tasks and intervention methods are unclear; which places these systems at risk of a breach.
☐	☑	Encryption	No encryption of customers credit card information that is accepted, processed, transmitted, and stored locally. Needs to be implemented to ensure confidentiality of customers sensitive information.
☐	☑	Password management system	No password management system currently in place which sometimes affect the productivity of IT department.
☑	☐	Locks (offices, storefront, warehouse)	All physical locations of the company i.e. their main offices, store front, and warehouse of products, have sufficient locks.
☑	☐	Closed-circuit television (CCTV) surveillance	Up-to-date closed-circuit television (CCTV) surveillance on all locations.
☑	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)	Every location has a functioning fire detection and prevention systems.

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice	Explanation
☐	☑	Only authorized users have access to customers' credit card information.	Currently, all employees have access to the company's internal data.
☐	☑	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.	Credit card information is not encrypted and all employees currently have access to internal data, including customers' credit card information.
☐	☑	Implement data encryption procedures to better secure credit card transaction touchpoints and data.	The company does not currently use encryption to better ensure the confidentiality of customers' financial information.
☐	☑	Adopt secure password management policies.	Minimal password policies in place and no password management system is currently in place.

General Data Protection Regulation (GDPR)

Yes	No	Best practice	Explanation
☐	☑	E.U. customers' data is kept private/secured.	No measures in place currently to ensure the confidentiality of customers data.
☑	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.	The IT department has established a plan to notify E.U. customers within 72 hours if there is a security breach.

☐	☑	Ensure data is properly classified and inventoried.	Assets have been inventoried, but not classified.
☑	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.	Privacy policies, procedures, and processes have been developed and are enforced among IT department, to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice	Explanation
☐	☑	User access policies are established.	No controls – PoLP/Separation of duties – are in place.
☐	☑	Sensitive data (PII/SPII) is confidential/private.	No encryption in place to better ensure the confidentiality of PII/SPII of customers.
☑	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.	IT department has ensured availability and integrated controls to ensure data integrity.
☐	☑	Data is available to individuals authorized to access it.	Data is available to access by all employees. Access to data should be limited to only employees who needs it to do their jobs by PoLP.

Recommendations (optional):

Multiple controls need to be implemented to improve Botium Toys' security posture and better ensure the confidentiality of sensitive information, including: Least Privilege, disaster recovery plans, password policies, separation of duties, an IDS, ongoing legacy system management, encryption, and a password management system.

To address gaps in compliance, Botium Toys needs to implement controls such as Least Privilege, separation of duties, and encryption. The company also needs to properly classify assets, to identify additional controls that may need to be implemented to improve their security posture and better protect sensitive information.